Análisis y corrección de vulnerabilidades con OWASP ZAP

Proyecto: ClientesBlazorApp (Blazor Web App, .NET 10) | Sitio analizado: http://localhost:5001 | ZAP 2.17.0 | Fecha: 12 de octubre de 2026

1. Resumen

Se ejecutó el análisis sobre el mismo sitio y con el mismo alcance (15 endpoints) antes y después de aplicar las correcciones. Las alertas medias y bajas se eliminaron; solo permanecen 3 alertas informativas, que no representan una vulnerabilidad y se justifican más abajo.

Nivel de riesgo	Antes (Informe_ZAP_Antes.html)	Después (Informe_ZAP_Despues.html)
Alto	0	0
Medio	4	0
Bajo	1	0
Informativo	3	3
Total de tipos de alerta	**8**	**3**

2. Tabla comparativa de resultados

Alerta encontrada	Riesgo	Instancias antes / después	Corrección realizada	Resultado final
CSP: Directiva Wildcard	Medio	5 / 0	CSP completa en Program.cs con fuentes restringidas a 'self'.	**Corregida**
CSP: Failure to Define Directive with No Fallback	Medio	5 / 0	Se agregaron base-uri, form-action y frame-ancestors.	**Corregida**
CSP: script-src unsafe-inline	Medio	5 / 0	script-src 'self'; se quitaron el onclick en línea y <ImportMap />.	**Corregida**
CSP: style-src unsafe-inline	Medio	5 / 0	style-src 'self'; los style en línea pasaron a clases en app.css.	**Corregida**
Falta encabezado X-Content-Type-Options	Bajo	5 / 0	Header X-Content-Type-Options: nosniff.	**Corregida**
Divulgación de información: Comentarios sospechosos	Informativo	1 / 1	No requiere modificación.	**Falso positivo**
Aplicación Web Moderna	Informativo	5 / 5	No requiere modificación.	**Informativa**
Respuesta de Gestión de Sesión Identificada	Informativo	2 / 2	No requiere modificación.	**Informativa**

Las instancias son las veces que ZAP reportó cada alerta (una por URL o respuesta afectada). Estados posibles: Corregida, Mitigada, No corregida, Informativa, Falso positivo. En este análisis no quedó ninguna alerta como No corregida.

3. Descripción de cada alerta y resultado

CSP: Directiva Wildcard (Medio) - Corregida

Qué es: la respuesta solo traía *Content-Security-Policy: frame-ancestors 'self'*. Al no definir las demás directivas (script-src, style-src, img-src, connect-src, font-src, object-src...), el navegador permite cargar contenido desde cualquier origen.
Riesgo: facilita ataques de inyección como XSS.
Corrección: en Program.cs se agregó un middleware que envía una CSP completa (default-src 'self'; script-src 'self'; style-src 'self'; img-src 'self' data:; font-src 'self'; connect-src con el WebSocket de la app; object-src 'none').
Resultado: la alerta ya no aparece en el segundo análisis.

CSP: Failure to Define Directive with No Fallback (Medio) - Corregida

Qué es: faltaban directivas que no heredan de default-src, como *form-action* y *base-uri*.
Riesgo: un atacante podría redirigir formularios a otro sitio o cambiar la URL base de la página.
Corrección: se agregaron base-uri 'self', form-action 'self' y frame-ancestors 'none'.
Resultado: eliminada.

CSP: script-src unsafe-inline (Medio) - Corregida

Qué es: sin una directiva script-src restrictiva, se aceptan scripts en línea.
Riesgo: es el vector típico de XSS, porque un script inyectado se ejecutaría.
Corrección: script-src 'self'. Para que la app siguiera funcionando se eliminó el atributo onclick en línea de NavMenu.razor (sustituido por un listener en wwwroot/js/interop.js) y la etiqueta <ImportMap /> de App.razor.
Resultado: eliminada.

CSP: style-src unsafe-inline (Medio) - Corregida

Qué es: sin style-src restrictivo se aceptan estilos en línea.
Riesgo: permite inyección de estilos que alteren la interfaz o filtren información.
Corrección: style-src 'self'. Los atributos style de Clientes.razor se movieron a las clases avatar-cliente e icono-grande en wwwroot/app.css.
Resultado: eliminada.

Falta encabezado X-Content-Type-Options (Bajo) - Corregida

Qué es: no se enviaba X-Content-Type-Options: nosniff.
Riesgo: algunos navegadores podrían interpretar un archivo como un tipo distinto al declarado (MIME sniffing).
Corrección: el mismo middleware envía X-Content-Type-Options: nosniff.
Resultado: eliminada. Como endurecimiento adicional se agregaron Referrer-Policy y Permissions-Policy, y se ocultó el header Server: Kestrel.

Divulgación de información: Comentarios sospechosos (Informativo) - Falso positivo

Qué es: ZAP busca palabras como USER dentro de comentarios y la encontró en ReconnectModal.razor.js.
Por qué no se modificó: el comentario es de la plantilla de Blazor ("...so the user can continue using the app as quickly as possible") y no contiene credenciales, rutas internas ni datos sensibles. La coincidencia es solo la palabra "user" en inglés, por lo que es un falso positivo.

Aplicación Web Moderna (Informativo) - Informativa

Qué es: ZAP detecta que la página usa JavaScript dinámico (Blazor Server) y sugiere usar el spider Ajax para explorarla.
Por qué no se modificó: es solo una observación sobre la tecnología de la aplicación, no una vulnerabilidad. No hay nada que corregir.

Respuesta de Gestión de Sesión Identificada (Informativo) - Informativa

Qué es: ZAP identifica la cookie .AspNetCore.Antiforgery como un identificador de sesión.
Por qué no se modificó: es la cookie antiforgery de ASP.NET Core, que protege contra CSRF y ya se envía con HttpOnly y SameSite=Strict. Es una protección funcionando, no una debilidad.

4. Archivos modificados

Archivo	Cambio
Program.cs	Middleware con headers de seguridad (CSP completa, nosniff, Referrer-Policy, Permissions-Policy) y ocultar header Server.
Components/App.razor	Se quitó <ImportMap />.
Components/Layout/NavMenu.razor	Se quitó el onclick en línea.
wwwroot/js/interop.js	Listener que reemplaza el onclick del menú.
wwwroot/app.css	Clases avatar-cliente e icono-grande.
Components/Pages/Clientes.razor	Estilos en línea cambiados por clases CSS.

5. Conclusión

Las 5 alertas con riesgo medio y bajo se corrigieron con una política de seguridad de contenido (CSP) completa y el header X-Content-Type-Options, ajustando el código (estilos y scripts en línea) para que sea compatible con esa política. Las 3 alertas informativas restantes no son vulnerabilidades y se documentaron con su justificación técnica. El análisis cubrió únicamente la aplicación Blazor (localhost:5001), no la API.